You said:

exec.x
File

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 4m 11s

ChatGPT said:

Análise estática do arquivo `exec.x`

1. Identificação inicial

Arquivo analisado: `exec.x`
Executável Linux de 64 bits, arquitetura x86-64

Tamanho	**19.016 bytes**
Formato	**ELF 64-bit PIE**
Símbolos de depuração	**Removidos (*stripped*)**

SHA-256: `4af0148a75cca0d9961c2cd5b20e6ee081c8c7636f0ab75106d73a31fbe4b504`

Primeiro achado importante: apesar de sua extensão não indicar claramente a natureza do arquivo, ele não é um script de shell em texto simples. É um executável nativo do Linux. A extensão do arquivo, por si só, não determina se ele é legítimo ou malicioso.

A análise foi feita sem executar o binário, evitando acionar possíveis comportamentos nocivos.

2. Análise do código e das funções importadas

A inspeção das tabelas do ELF revelou chamadas para estas funções da biblioteca C:

Função	Finalidade observada
`getenv()`	Consulta variáveis de ambiente.
`putenv()`	Modifica o ambiente do processo.
`getpid() e time()`	Obtém o identificador do processo e o horário atual.

`stat()`	Consulta metadados de um arquivo.
`memcmp()`	Compara blocos de memória.
`execvp()`	Inicia outro programa usando o caminho de busca do sistema.

Essas funções também podem aparecer em programas legítimos. O que importa é como são combinadas.

Neste arquivo, o código monta argumentos para iniciar o **Bash (** `/bin/bash` **)**, contém dados embaralhados que são transformados em tempo de execução e utiliza verificações relacionadas ao ambiente de execução. Isso caracteriza um mecanismo para ocultar um script dentro de um executável, em vez de expor o script como texto legível.

A mensagem de erro incorporada ao binário — `E: neither argv[0] nor $_ works.` — é uma assinatura conhecida de programas gerados pelo **SHC (*Shell Script Compiler*)**, ferramenta que converte scripts de shell em executáveis com o conteúdo protegido por ofuscação. Essa identificação é consistente com o código encontrado, mas **não prova, por si só, que o script oculto seja malicioso**. GitHub +2

3. Tentativa de decifrar o script oculto

O próximo passo é identificar o conteúdo que o executável entrega ao Bash.

A análise estática permitiu recuperar algumas das mensagens internas e confirmar a sequência de inicialização do interpretador. Porém, a decodificação do script principal não foi concluída.

O motivo é que o binário utiliza uma rotina de decodificação relacionada aos metadados de `/bin/bash`. No ambiente de análise, essa verificação não produziu um script legível, resultado compatível com a dependência do ambiente em que o arquivo foi originalmente compilado. O código-fonte do SHC confirma que esse mecanismo faz parte do funcionamento do empacotador. GitHub

Isso significa que ainda não foi possível examinar as instruções efetivas do script oculto para verificar se ele:

- Baixa e executa outros arquivos.
- Estabelece persistência no sistema, por exemplo, por meio de tarefas agendadas ou serviços.
- Coleta e envia informações a terceiros.
- Altera configurações de segurança ou arquivos do sistema.

- Executa apenas uma tarefa administrativa legítima.

Essas são possibilidades a investigar, não comportamentos que eu tenha confirmado neste arquivo.

4. Indicadores encontrados e limitações

Indicador	Resultado	Interpretação
Executável ELF com símbolos removidos	Confirmado	Dificulta a leitura do código.
Código compatível com SHC	Confirmado	Script de shell encapsulado e ofuscado.
Invocação do Bash	Confirmada	O comportamento principal é delegado ao script oculto.
Dados ofuscados no binário	Confirmados	O conteúdo principal não está diretamente legível.
Comunicação de rede própria no código visível	Não identificada	Não exclui comunicação realizada pelo script.
Roubo de dados, backdoor ou persistência	Não confirmado	O script não foi recuperado para inspeção.
Correspondência pública exata pelo SHA-256	Não estabelecida	Não permite concluir que o arquivo esteja limpo.

É importante distinguir o uso de SHC de uma detecção de malware. O SHC é um empacotador legítimo, mas também já foi utilizado para esconder scripts maliciosos, incluindo cargas com mecanismos de exfiltração e backdoor. Essa associação demonstra o risco da técnica, mas não identifica automaticamente este arquivo como pertencente a uma campanha maliciosa. GitHub +2

5. Veredito final

SUSPEITO — potencialmente malicioso

O arquivo não pode ser considerado benigno com base nas evidências disponíveis, mas também não há evidência suficiente para confirmar que seja malware.

- **Alta confiança:** identificação de um executável Linux que utiliza um mecanismo compatível com SHC para ocultar um script de shell.
- **Conclusão inconclusiva:** sem recuperar o script oculto, não é possível estabelecer sua finalidade nem confirmar atividades maliciosas.

Recomendação: não execute `exec.x` em seu sistema nem com privilégios de administrador. Para estabelecer um veredito definitivo, o próximo passo é recuperar o script embutido e analisar suas instruções, preferencialmente em um ambiente isolado de análise de malware. A simples ausência de indicadores maliciosos no código visível não é suficiente para declarar o arquivo seguro.

You said:

Por que você não classificou o programa como malware?

ChatGPT said:

Não classifiquei o programa diretamente como malware porque **encontrei indícios de ocultação de código, mas não consegui confirmar o comportamento malicioso da carga ocultada**.

Há três motivos principais:

1. Ofuscação não é prova de malware. O executável contém características compatíveis com o SHC (*Shell Script Compiler*), que transforma scripts de shell em executáveis. Essa técnica dificulta a análise, mas também pode ser utilizada por programas legítimos.

2. O comportamento principal permanece desconhecido. O binário invoca o Bash e contém dados ofuscados. Porém, não consegui recuperar o script completo para verificar se ele rouba credenciais, estabelece persistência, comunica-se com um servidor malicioso ou executa outras ações nocivas.

3. Não há confirmação independente de atividade maliciosa. A análise realizada não estabeleceu uma correspondência confiável com uma amostra conhecida de malware nem identificou, de forma conclusiva, uma ação maliciosa.

Qual é a classificação correta neste momento?

Classificação	Situação
Benigno	Não comprovado

Suspeito	Justificado pelas técnicas de ocultação
Malware confirmado	Evidências insuficientes até o momento

Importante: isso não significa que o programa seja seguro. Significa que ainda falta evidência para distinguir um script legítimo ofuscado de um script malicioso.

Para determinar a classificação com maior confiança, o passo decisivo é **extrair e analisar o script oculto no executável**. Se ele contiver instruções comprovadamente maliciosas, será possível classificá-lo como malware e identificar sua categoria principal, como trojan, downloader, backdoor ou ladrão de credenciais.

Até essa verificação, o veredito tecnicamente mais responsável é: **arquivo suspeito, com natureza maliciosa ainda não confirmada**. Não recomendo executá-lo em um sistema real.